PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Pare-feu et pots de miel

09-420 PSE-ER F4-7 Équipements de sécurité - firewall et honeypot — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le pare-feu protège le réseau du monde extérieur mais ne protège pas de la menace interne ni des mots de passe faibles.
2. Les trois familles de pare-feu sont le filtre de paquets, la passerelle de circuits qui relaie le TCP et la passerelle d'applications qui sectionne les flux.
3. Le pot de miel à forte interaction offre de véritables accès aux attaquants, ce qui est puissant pour l'observation mais dangereux.

Synthèse sur le pare-feu

Notion	À retenir
Rôle et limites	Protège du monde extérieur, garde des utilisateurs à l'intérieur, réduit les machines à surveiller. **Indispensable mais jamais suffisant** : rien contre le **monde intérieur** ni les **mots de passe faibles**. Politique : tout autoriser puis interdire, ou (plus sûr) **tout interdire puis ouvrir**.
Les types de pare-feu	**Filtre de paquets** (IP, ports, contenu ; **sans contexte** ; fragments et FTP difficiles) ; **passerelle de circuits** (relaie TCP) ; **passerelle d'applications** (programme par service, sectionne les flux) ; **stateful multilayer** (les trois).
Pare-feu récents	Inspection **stateful** et applicative, IA, filtrage HTTP/URL, antivirus, NAT, tunnels **IPsec**/PPTP/L2TP, proxy, **IDS/IPS**. Ex. : Checkpoint, Cisco PIX/ASA, `iptables` (Linux), Packet Filter (BSD).
Poste de travail	Protection individuelle : antivirus, anti-spywares, **pare-feu personnel**, correctifs de sécurité.

Les pots de miel

Notion	À retenir
Principe et objectifs	Machine à **sécurité faible** pour **distraire** l'attaquant et **découvrir** de nouvelles techniques/outils. Ex : **Honeynet**, **NoAH**.
Faible et forte interaction	**Faible interaction** : récolte d'infos à **moindre risque** (`honeyd`, `honeytrap`, `nepenthes`, `Specter`). **Forte interaction** : **accès réels**, risque **important** (`ROO` `HoneyWall`).

Pièges et confusions

⚠ Croire que le pare-feu est suffisant car il ne remplace pas la sensibilisation des utilisateurs ou la surveillance quotidienne.

⚠ Confondre le filtre de paquets, qui n'a pas de notion de contexte, avec l'inspection stateful qui suit l'état des connexions.

⚠ Penser que la politique consistant à tout autoriser puis restreindre est la plus sûre, alors que c'est celle qui consiste à tout interdire puis ouvrir sélectivement.

⚠ Oublier que le pot de miel à forte interaction exige un déploiement prudent à cause des risques importants.

⚠ Confondre la passerelle de circuits qui relaie les connexions TCP avec la passerelle d'applications qui utilise un programme spécifique par service.

Sigles et définitions

Pare-feu	équipement ou logiciel qui contrôle les accès entrants et sortants d'un réseau
Filtre de paquets	type de pare-feu qui trie les paquets sans notion de contexte
Passerelle de circuits	type de pare-feu qui relaie les connexions TCP
Passerelle d'applications	type de pare-feu qui définit un programme spécifique par application
Pot de miel	machine connectée au réseau et volontairement peu sécurisée pour distraire un attaquant
Honeynet	réseau de pots de miel

Auto-test

1. Quelle politique de configuration est la plus sûre ?
2. Quel outil de pare-feu du noyau Linux permet de bâtir un serveur simple ?
3. Comment appelle-t-on un réseau de pots de miel ?
4. Quel type de pare-feu analyse les flux en gardant la trace de l'état des connexions ?
5. Citez un exemple de pot de miel à faible interaction.

Réponses : **1.** Tout interdire puis ouvrir sélectivement · **2.** iptables · **3.** Honeynet · **4.** Inspection stateful · **5.** honeyd, honeytrap, nepenthes ou Specter

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.